

School Audit Report

Audit Date: 28th January 2020

Auditor: Arrienne Stanyon

Hampstead Hill Primary

The school have been through a challenging time in relation the Data Protection lead due to maternity leave and lack of an effective replacement. The member of staff is now back in post and has made changes that have positively affected their compliance. The school will see the benefits of a sustained compliance programme and should focus on ensuring all their current practices adhere to the data protection regulations and advice given by DPE. A plan should then be put in place for areas such as the Record of Processing to ensure continued improvements are made.

The following report highlights the areas discussed during the visit, observations for improvements and the next steps.

Previous Audit Review

- Training has been completed with only 10 members of staff outstanding
- Have changed filters on the computer to track searches on the system
- Checklists- looked at clear desk
- Policies have been adopted from DPE templates

Recommendations-

- Consider giving all staff their own email accounts. This will avoid data breaches as some of the information will be personal to the staff member
- Ensure all laptops are encrypted
- Communicate lock screen info to staff (windows and L or other method for Macs)
- Ensure staff are aware not to share data when in other roles. As some staff members work as nannies for the children outside of school time, they must be aware they cannot share data obtained through the work with the school
- Try to keep trip data secure and consider about using a phone or tablet instead of paper
- Look at consent forms to ensure they are compliant. Remember to be specific
- Complete a DPIA for school base

Best Practice Checklists

The Best Practice Checklists are available on the Knowledge Bank and can be useful for many different purposes.

Each area contains either a guidance document, model policy or template that can be useful. Associated to each area is a checklist which comprises of a series of questions in relation to the particular area. These will help to direct the school as to what they should be doing in each area as far as personal data is concerned and it forms parts of the next steps for GDPR compliance.

The checklists can be printed and shared with other members of staff or governing bodies in order to track improvements.

Most importantly they will be used to focus future DPE visits so that the Data Protection Officer can be most of use and provide additional support and guidance.

Please endeavour to complete some areas before the next visit.

Training

We discussed training options and it was explained that all members of staff need to be data protection trained and the training should be revisited annually.

Some of the staff do not have individual accounts in order to log into the Knowledge Bank. Those staff should complete the training and a record kept by the school to demonstrate that training has taken place.

Additional training resources will be available on the Knowledge Bank. These short modules (5-10minutes) will include:

- Subject Access Request
- Personal Data Breaches
- Information Security
 - Clear Desk
 - Physical Security
 - Data Classification
 - Password Security

Please ensure all members of staff have completed the 101 module and those who have done so can use the new modules as refresher training.

Subject Access Request and Breach Review

Breaches-

The school have no new breaches reported since the last visit. Please ensure all staff are aware of what a breach is and how they should respond to one. This training will be crucial in avoiding harm to data subjects and regulatory action for the school.

Subject Access Requests-

The school have had 2 SAR's and responded to them in a timely manner and been able to complete the request within the time frame. Please use these requests to identify any opportunity for improvements, note any time-consuming aspects that be reduced and continue to promote awareness with staff.

Visible Risk Observations

Classroom 1

- **Allergy Information on display**

Restrict data, without general display. Ensure the availability of data to the required staff without sharing the data to unauthorised staff. Consider actively pushing to staff, rather than a passive and open display of data. View our NHS Best Practice on the Knowledge Bank: <https://kb.dataprotection.education/index.php/best-practice/nhs-data-sharing>

Classroom 2

- **Personal Data**

Sign in sheet- keep only the current sheet and file the others

Next steps-

- Ensure all members of staff have completed annual data protection training
- Ensure ICO registration is up-to-date and that the contact details are correct
- Data Protection Education should be registered with the ICO as your DPO
- Complete some checklists before the next visit
- All Breaches and Subject Access Requests must be logged (you may use the DPE logs on the Knowledge Bank)
- Implement data protection policies and ensure all staff have read and understood